Enumeracja Web

Spis treści

Wstęp 3
Przygotowanie środowiska 6
Uruchamianie maszyn 7
Połączenie OpenVPN 8
Teoria 9
Czym jest enumeracja zasobów? 10
Popularne narzędzia do enumeracji zasobów 11
Co można znaleźć podczas enumeracji? 12
Głębokie ukrycie zasobów - wady i zalety 13
Historia przypadków 14
Podsumowanie 16
Zadania 17
Zadanie 4.1: Enumeracja katalogów 18
Zadanie 4.2: Enumeracja plików 19
Zadanie 4.3: Enumeracja hostów 20
Zadanie 4.4: Enumeracja subdomen 21
Zadanie 4.5: Enumeracja parametrów HTTP 22
Referencje 23

Wstęp

W tym dziale zajmiemy się przede wszystkim **poszukiwaniem ukrytych** przed nami **plików** i **katalogów** osadzonych na serwerach i w innych miejscach sieci. Dobrze skonfigurowany serwer nie pozwoli nam wyświetlić zawartości, do której nie znamy adresu. Wykorzystamy jednak **ataki słownikowe**, aby odnaleźć zawartość o popularnych nazwach.

Wstęp

Wykorzystamy dwa popularne narzędzia: Gobuster i ffuf:

1. **Gobuster** to narzędzie do brutalnego skanowania katalogów i plików na serwerach WWW. Wykorzystuje listę słów do odkrywania ukrytych katalogów i plików poprzez wysyłanie wielu zapytań HTTP.
2. **ffuf** (Fuzz Faster U Fool) to szybkie i elastyczne narzędzie do fuzzowania i odkrywania katalogów na stronach internetowych. Obsługuje różne typy ataków, takie jak odkrywanie ukrytych plików oraz katalogów. Można je dostosować za pomocą różnych list słów i ładunków.

Wstęp

Wyżej wspomniane oprogramowanie wymaga do swojego działania słowników. Wykorzystamy do tego celu **SecLists**. Są one domyślnie zainstalowane w Kali Linux, jednak na wszelki wypadek podajemy dwie metody instalacji:

```
sudo apt install seclists #instaluje do /usr/share/seclists
git clone https://github.com/danielmiessler/SecLists.git
```

Wykorzystamy:

- /usr/share/seclists/Discovery/Web-Content/raft-small-directories.txt - katalogi
- /usr/share/seclists/Discovery/Web-Content/raft-small-files.txt - pliki
- /usr/share/seclists/Discovery/DNS/fierce-hostlist.txt - nazwy wirtualnych hostów
- /usr/share/seclists/Discovery/DNS/subdomains-top1million-5000.txt - subdomeny
- /usr/share/seclists/Passwords/Common-Credentials/xato-net-10-million-passwords-100000.txt - hasła

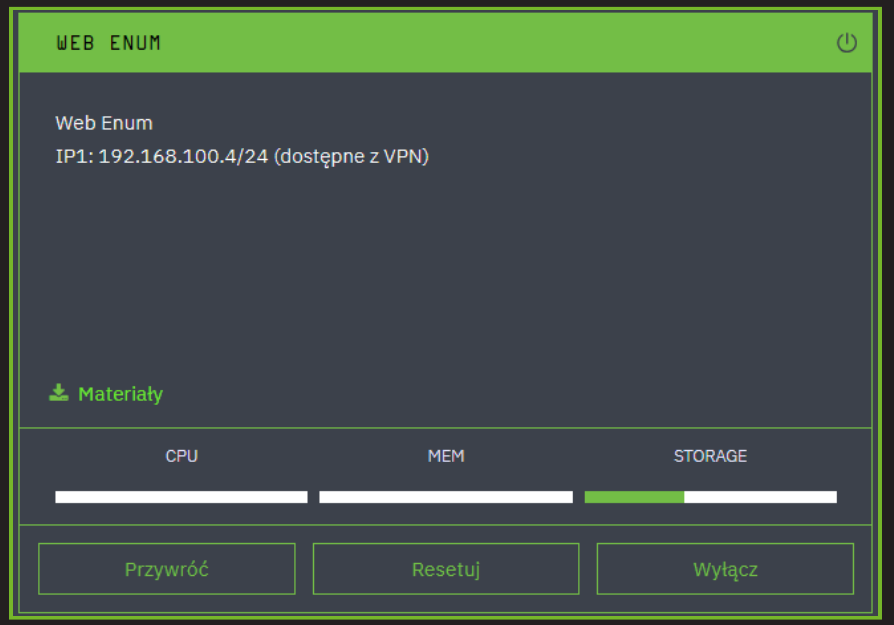
Uwaga! Ścieżki słowników zmieniają się niemal przy każdej aktualizacji. Wobec tego niektóre użyte polecenia mogą wymagać modyfikacji.

POLSKO-JAPOŃSKA AKADEMIA TECHNIK KOMPUTEROWYCH

Przygotowanie środowiska

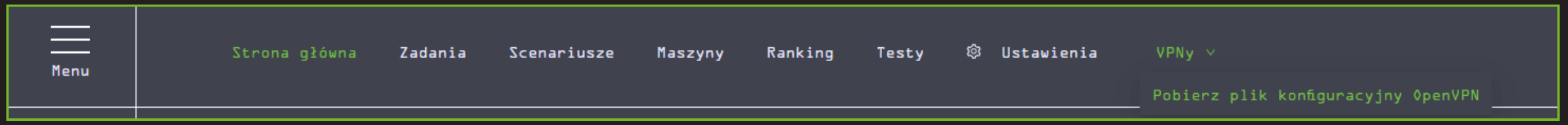
Uruchamianie maszyn

Przed rozpoczęciem upewnij się, że maszyna Web Enum jest włączona.
Jeżeli coś się zepsuje, w każdej chwili możesz ją przywrócić do stanu początkowego.



Podczas tych zajęć wszystkie polecenia wykonujemy bezpośrednio na maszynie Kali!

Połączenie OpenVPN



Połączenie OpenVPN jest niezbędne do rozwiązania zadań.
Aby połączyć się z siecią VPN, należy pobrać plik konfiguracyjny OpenVPN z rozwijanego menu „**VPNy**” na stronie głównej.
Następnie należy wykonać komendę:

```
sudo openvpn /sciezka/do/pliku.ovpn
```

Komendy, będące częścią zadań, należy rozwiązywać w osobnej karcie/oknie terminala!

POLSKO-JAPOŃSKA AKADEMIA TECHNIK KOMPUTEROWYCH

Teoria

Czym jest enumeracja zasobów?

Enumeracja zasobów sieciowych to proces polegający na odkrywaniu ukrytych katalogów, plików i innych zasobów w infrastrukturze IT. Jest to kluczowy etap testów penetracyjnych, pozwalający na znalezienie niedostatecznie zabezpieczonych elementów systemu, które mogą stanowić furtkę dla potencjalnego atakującego. W ramach tego procesu można zidentyfikować m.in.:

- Ukryte katalogi i pliki,
- Panele administracyjne,
- Pliki konfiguracyjne zawierające dane dostępowe,
- Stare wersje aplikacji pozostawione na serwerze,
- Backupy, które mogą ujawniać wrażliwe informacje.

Popularne narzędzia do enumeracji zasobów

Do skutecznego przeszukiwania zasobów sieciowych służą specjalistyczne narzędzia, takie jak:

- DirBuster - narzędzie do brute-force’owego przeszukiwania katalogów na serwerach WWW,
- FFUF (Fuzz Faster U Fool) - szybki fuzzing HTTP, pozwalający na testowanie katalogów i plików,
- Gobuster - efektywne narzędzie do skanowania katalogów i subdomen.
- Wfuzz - narzędzie do fuzzingu HTTP, pozwalające testować nie tylko katalogi, ale i parametry aplikacji,
- DIRB - lekkie narzędzie do brute-force’owego wykrywania katalogów na serwerach WWW.

Co można znaleźć podczas enumeracji?

W trakcie testów często można natrafić na zasoby, które nie powinny być publicznie dostępne. Do najczęstszych odkryć należą:

- Panele administracyjne - takie jak /admin, /login, które mogą prowadzić do nieautoryzowanego dostępu,
- Pliki konfiguracyjne - np. config.php, web.config, database.yml, które mogą zawierać dane dostępowe do baz danych,
- Backupy i archiwa - pliki .zip, .tar, .sql, które mogą ujawniać poufne informacje,
- Stare wersje aplikacji - ukryte katalogi zawierające niezałatane podatności.

Głębokie ukrycie zasobów - wady i zalety

Wiele organizacji decyduje się na ukrywanie zasobów poprzez niepublikowanie linków czy stosowanie nietypowych nazw katalogów. Chociaż może to opóźnić atak, nie jest skutecznym zabezpieczeniem, ponieważ:

Zalety:

- Redukuje przypadkowy dostęp do wrażliwych zasobów,
- Może zmniejszyć ryzyko wykrycia przez mniej zaawansowanych atakujących.

Wady:

- Nie chroni przed dedykowanym skanowaniem,
- Może prowadzić do poczucia fałszywego bezpieczeństwa,
- Narzędzia do enumeracji nadal mogą ujawnić ukryte zasoby.

Historia przypadków

Uber (2016) - Atakujący odkryli publicznie dostępny backup, w którym znajdowały się klucze API i dane użytkowników. Skutkiem tego incydentu był wyciek danych dotyczących ponad 57 milionów kont.

Equifax (2017) - W wyniku niedostatecznie zabezpieczonego serwera testowego atakujący uzyskali dostęp do danych milionów klientów. Luka nie została załatana na czas, co skutkowało jednym z największych wycieków w historii.

NASA (2018) - Przechowywanie w niechronionych katalogach informacji o infrastrukturze doprowadziło do wycieku wrażliwych danych dotyczących wewnętrznych systemów agencji. Incydent wykazał poważne zaniedbania w polityce bezpieczeństwa.

Historia przypadków

Facebook (2019) - Odkryto, że na publicznych serwerach przechowywano niezaszyfrowane hasła milionów użytkowników. Sprawa ta wywołała burzę w mediach i postawiła pod znakiem zapytania praktyki bezpieczeństwa giganta technologicznego.

Microsoft (2021) - Na publicznie dostępnym serwerze pozostawiono logi zawierające dane użytkowników, co mogło doprowadzić do potencjalnych ataków phishingowych i przejęcia kont.

Podsumowanie

Enumeracja zasobów sieciowych jest kluczowym elementem testów penetracyjnych, pozwalającym na wykrycie ukrytych katalogów, plików oraz podatnych zasobów. Chociaż ukrywanie zasobów może opóźnić atak, nie stanowi skutecznej ochrony przed zaawansowanymi narzędziami do fuzzingu i skanowania. Historia pokazuje, że brak odpowiedniego zabezpieczenia może prowadzić do poważnych incydentów, dlatego organizacje powinny regularnie monitorować swoje zasoby i stosować najlepsze praktyki w zakresie bezpieczeństwa.

UWAGA!

Zawartość pakietu seclists zmienia się bardzo często i dostosowanie każdego polecenia do tych zmian jest fizycznie niemożliwe. Nazwy słowników i ścieżki do nich mogą być inne w chwili, kiedy rozwiązujesz te zadania, jednak sama metoda rozwiązania pozostaje niezmieniona.

POLSKO-JAPOŃSKA AKADEMIA TECHNIK KOMPUTEROWYCH

Zadania

Zadanie 4.1: Enumeracja katalogów

Celem zadania jest znalezienie dwóch ukrytych katalogów na stronie http://192.168.100.4/ i odwiedzenie ich.

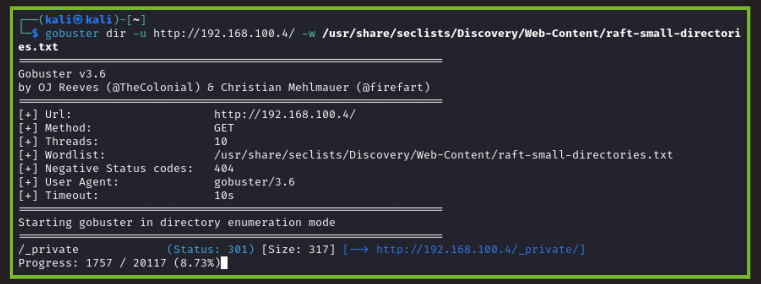
```
gobuster dir -u http://192.168.100.4/ -w /usr/share/seclists/Discovery/Web-Content/raft-small-directories.txt -r
```

lub

```
ffuf -w /usr/share/seclists/Discovery/Web-Content/raft-small-directories.txt -u http://192.168.100.4/FUZZ/
```

```
ffuf -w /usr/share/seclists/Discovery/Web-Content/raft-small-directories.txt -u http://192.168.100.4/FUZZ/ -fs <rozmiar>
```

Opcje:
-u URL
-w słownik,
-r - śledzenie przekierowań
-fs - filtr dla ffuf, aby nie wyświetlał odpowiedzi HTTP o konkretnym rozmiarze







Uwaga! Ścieżki słowników zmieniają się niemal przy każdej aktualizacji. Wobec tego niektóre użyte polecenia mogą wymagać modyfikacji.

Zadanie 4.2: Enumeracja plików

Celem zadania jest znalezienie ukrytego pliku php w katalogu http://192.168.100.4/_private/

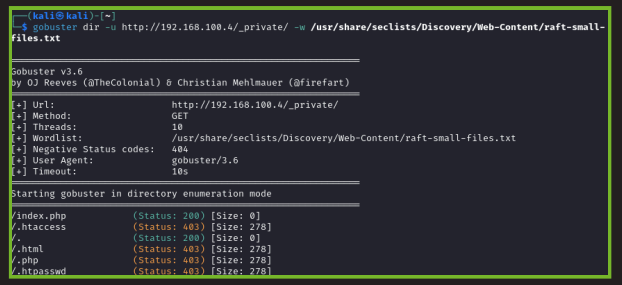
```
gobuster dir -u http://192.168.100.4/_private/ -w /usr/share/seclists/Discovery/Web-Content/raft-small-files.txt
```

lub

```
ffuf -w /usr/share/seclists/Discovery/Web-Content/raft-small-files.txt -u http://192.168.100.4/_private/FUZZ
```

```
ffuf -w /usr/share/seclists/Discovery/Web-Content/raft-small-files.txt -u http://192.168.100.4/_private/FUZZ -fs <rozmiar>
```

Opcje:
-u URL
-w słownik,
-fs - filtr dla ffuf, aby nie wyświetlał odpowiedzi HTTP o konkretnym rozmiarze





Uwaga! Ścieżki słowników zmieniają się niemal przy każdej aktualizacji. Wobec tego niektóre użyte polecenia mogą wymagać modyfikacji.

Zadanie 4.3: Enumeracja hostów

Celem zadania jest znalezienie ukrytego wirtualnego hosta skonfigurowanego na http://192.168.100.4

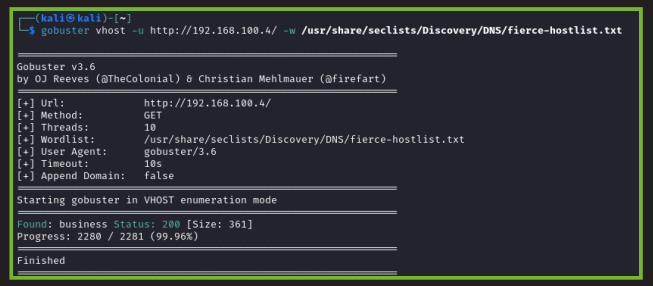
```
gobuster vhost -u http://192.168.100.4/ -w /usr/share/seclists/Discovery/DNS/fierce-hostlist.txt
```

lub

```
ffuf -w /usr/share/seclists/Discovery/DNS/fierce-hostlist.txt -u http://192.168.100.4/ -H 'Host: FUZZ'
```

```
ffuf -w /usr/share/seclists/Discovery/DNS/fierce-hostlist.txt -u http://192.168.100.4/ -H 'Host: FUZZ' -fs <rozmiar>
```

Opcje:
-u URL
-w słownik,
-fs - filtr dla ffuf, aby nie wyświetlał odpowiedzi HTTP o konkretnym rozmiarze
Krok opcjonalny: Znaleziony host można dopisać do pliku /etc/hosts







Uwaga! Ścieżki słowników zmieniają się niemal przy każdej aktualizacji. Wobec tego niektóre użyte polecenia mogą wymagać modyfikacji.

Zadanie 4.4: Enumeracja subdomen

Celem zadania jest znalezienie subdomeny domeny business.

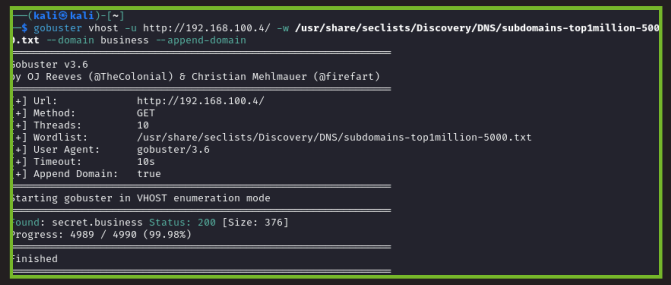
```
gobuster vhost -u http://192.168.100.4/ -w /usr/share/seclists/Discovery/DNS/subdomains-top1million-5000.txt --domain business --append-domain
```

lub

```
ffuf -w /usr/share/seclists/Discovery/DNS/subdomains-top1million-5000.txt -u http://192.168.100.4/ -H 'Host: FUZZ.business'
```

```
ffuf -w /usr/share/seclists/Discovery/DNS/subdomains-top1million-5000.txt -u http://192.168.100.4/ -H 'Host: FUZZ.business' -fs <rozmiar>
```

Opcje:
-u URL
-w słownik,
-fs - filtr dla ffuf, aby nie wyświetlał odpowiedzi HTTP o konkretnym rozmiarze





Uwaga! Ścieżki słowników zmieniają się niemal przy każdej aktualizacji. Wobec tego niektóre użyte polecenia mogą wymagać modyfikacji.

Zadanie 4.5: Enumeracja parametrów HTTP

Celem zadania jest znalezienie prawidłowego hasła dla parametru password: http://192.168.100.4/4.5.php?password=guess

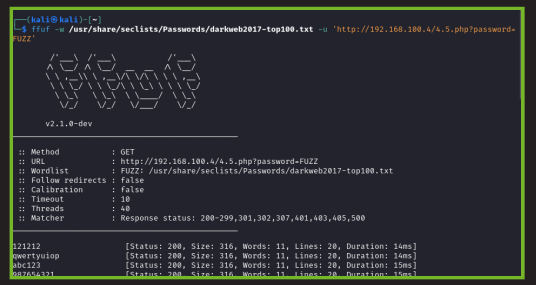
```
gobuster fuzz -u http://192.168.100.4/4.5.php?password=FUZZ -w /usr/share/seclists/Passwords/Common-Credentials/xato-net-10-million-passwords-100000.txt
```

lub

```
ffuf -w /usr/share/seclists/Passwords/Common-Credentials/xato-net-10-million-passwords-100000.txt -u 'http://192.168.100.4/4.5.php?password=FUZZ'
```

```
ffuf -w /usr/share/seclists/Passwords/Common-Credentials/xato-net-10-million-passwords-100000.txt -u 'http://192.168.100.4/4.5.php?password=FUZZ' -fs <rozmiar>
```

Opcje:
-u URL
-w słownik,
-fs - filtr dla ffuf, aby nie wyświetlał odpowiedzi HTTP o konkretnym rozmiarze (w tym wypadku 316)







Uwaga! Ścieżki słowników zmieniają się niemal przy każdej aktualizacji. Wobec tego niektóre użyte polecenia mogą wymagać modyfikacji.

Referencje

- FUZZ manual: https://www.unix.com/man-page/debian/1/FUZZ/
- Strona projektu Gobuster: https://github.com/OJ/gobuster
- Security through obscurity: https://tinyurl.com/sectobs
- Manual programu Hydra: https://www.kali.org/tools/hydra/